

Defense:

Prevent, Mitigate, Respond & Test

Taller de Seguridad

Ing. Martin Di Paola - Fiuba



Barings Bank
(english bank founded in 1762)

Nick Leeson

{ Trading Manager
and
his own Supervisor



2 roles in 1
person



no separation

no minimum

no monitoring

Nick Leeson

{ Trading Manager
and
his own Supervisor



2 roles in 1
person

no separation

no minimum

no monitoring

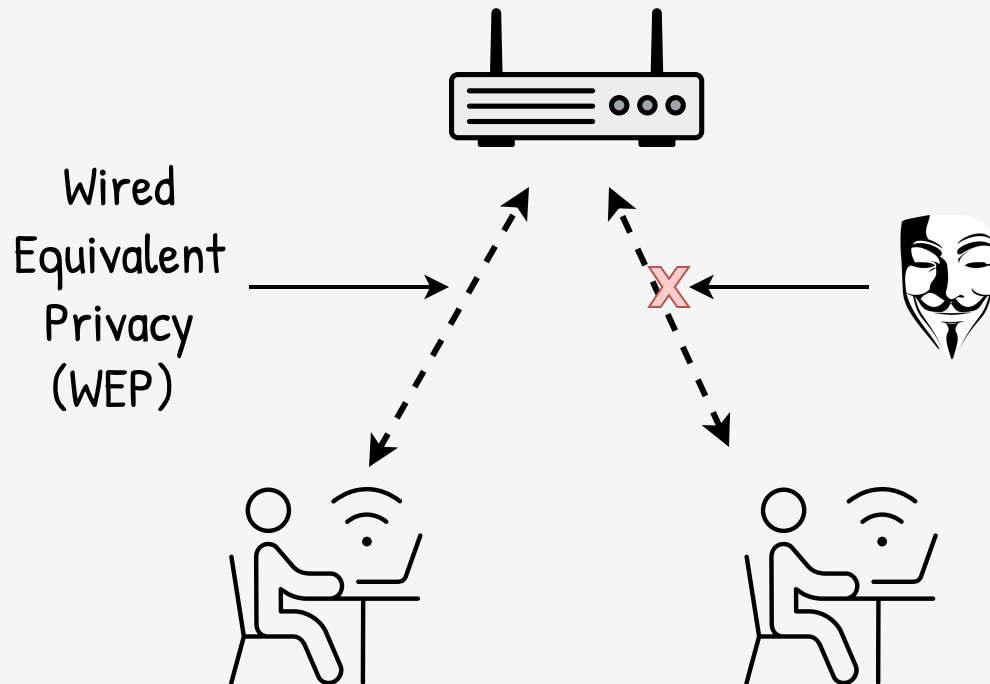
Losses for 1400
million dollars

Bankruptcy in 1995;
bank sold by 1 pound
sterling

1762 - 1995
(264 years)



Nick Leeson, captured in Kuala Lumpur



WEP

1997

(closed-ish)

(impl)

WEP

1997

xx-2001

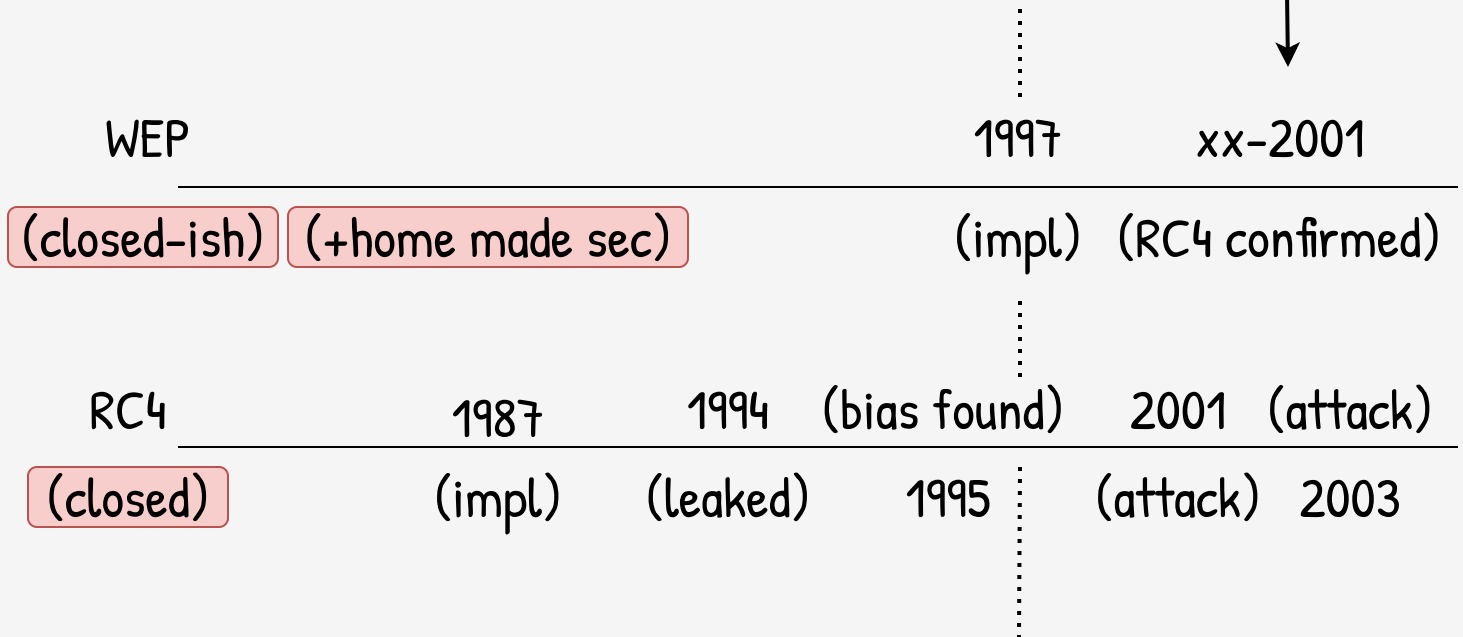
(closed-ish)

(impl) (RC4 confirmed)

WEP	1997	xx-2001
(closed-ish)	(impl)	(RC4 confirmed)

RC4	1987	1994	(bias found)
(closed)	(impl)	(leaked)	1995

And now, what
do we do?

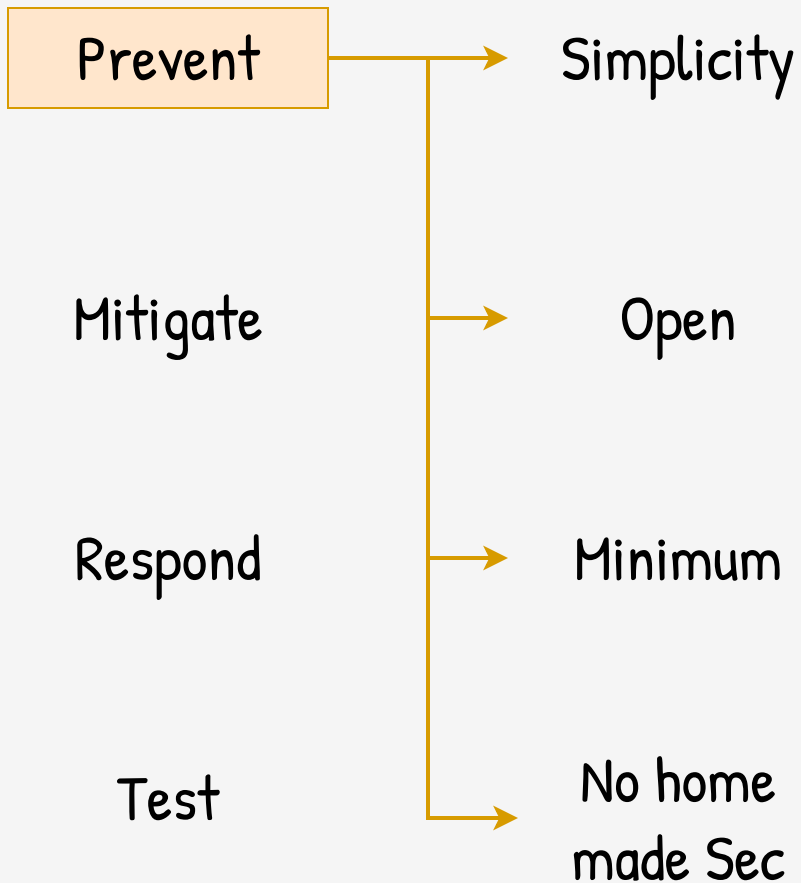


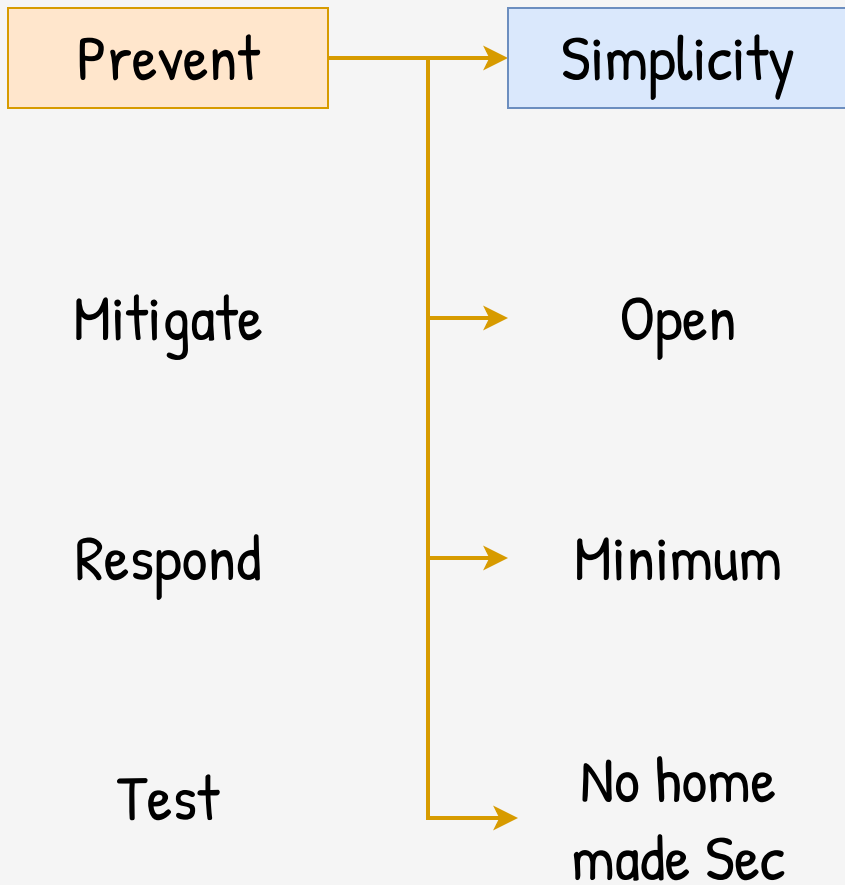
Prevent

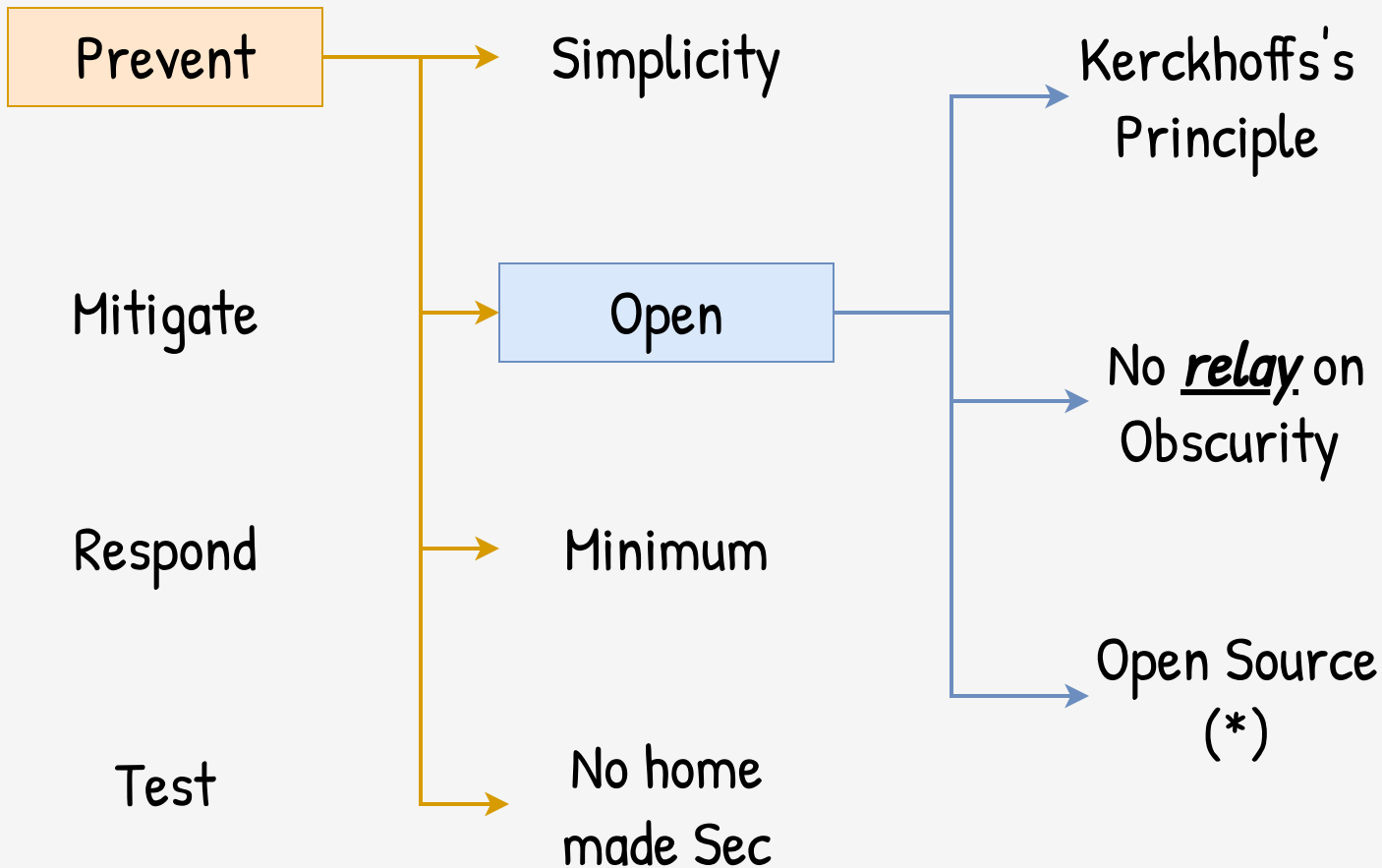
Mitigate

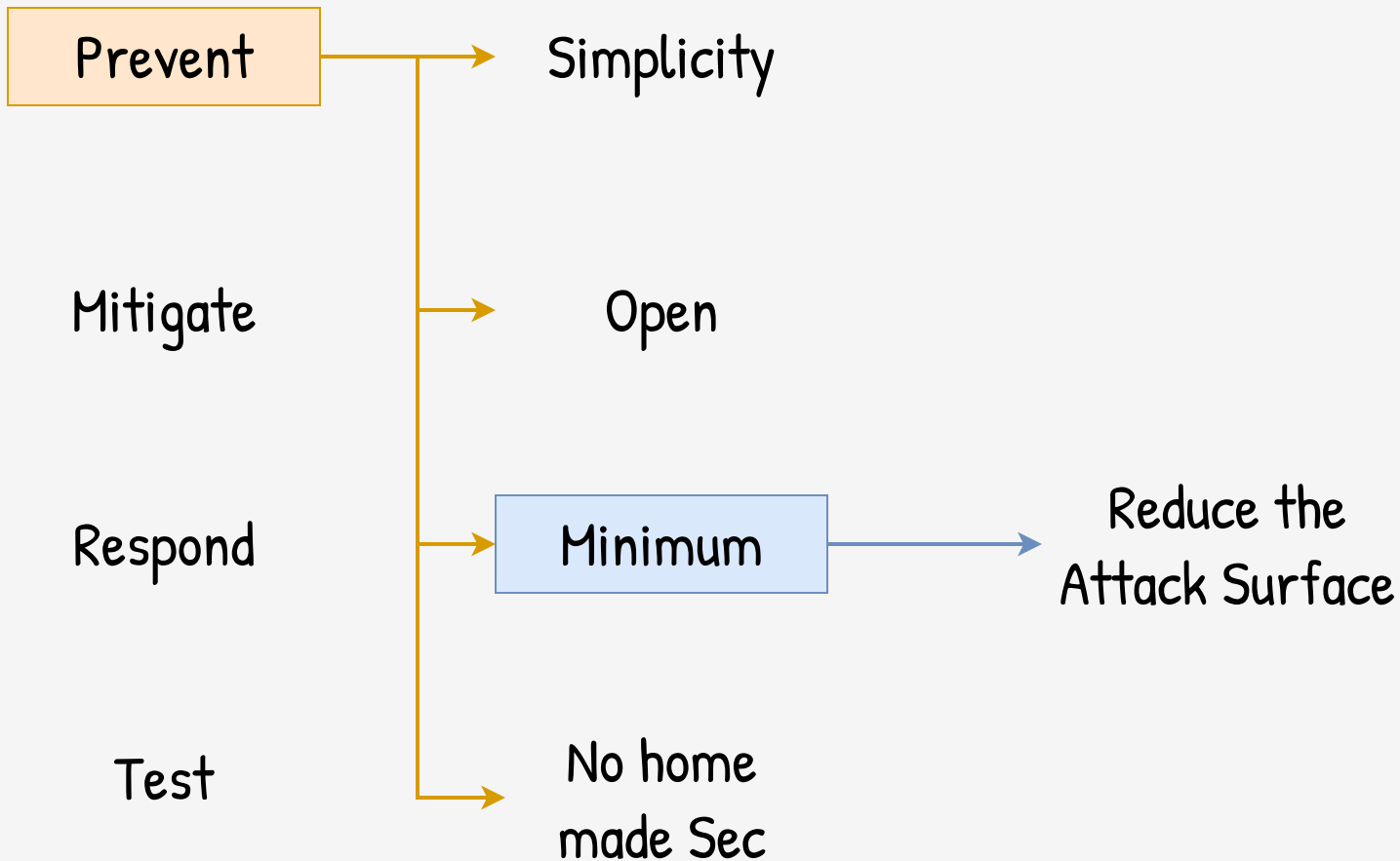
Respond

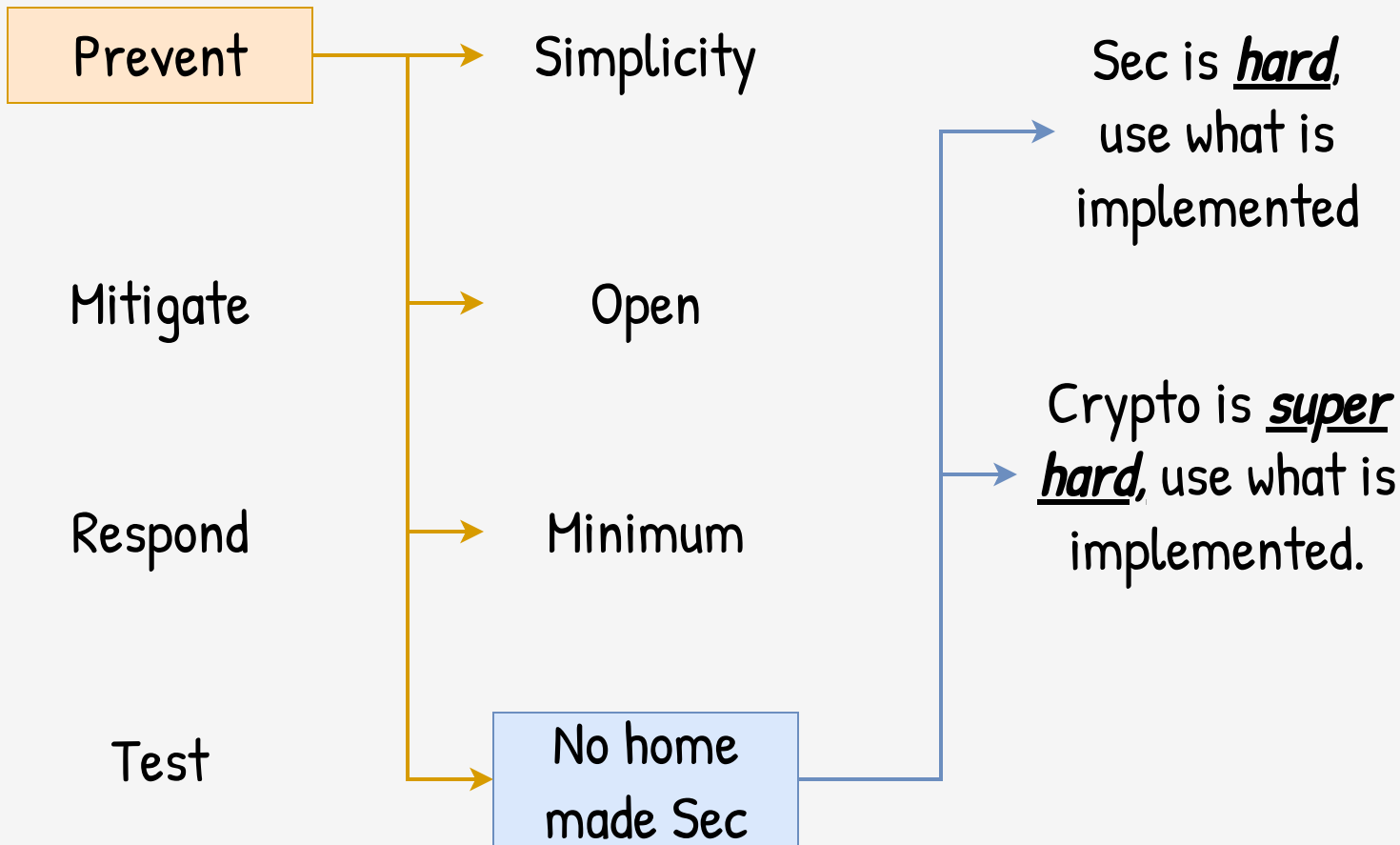
Test

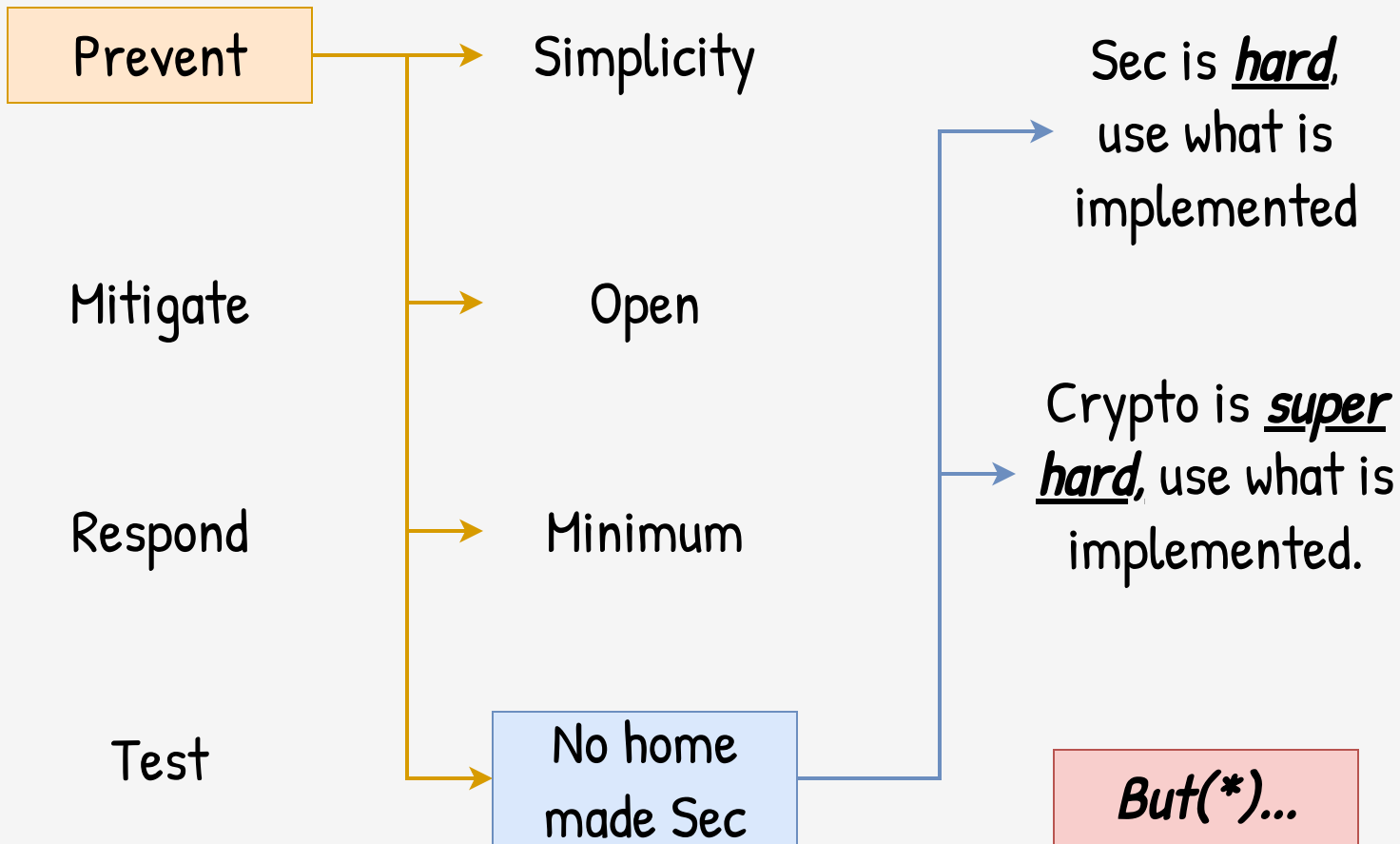


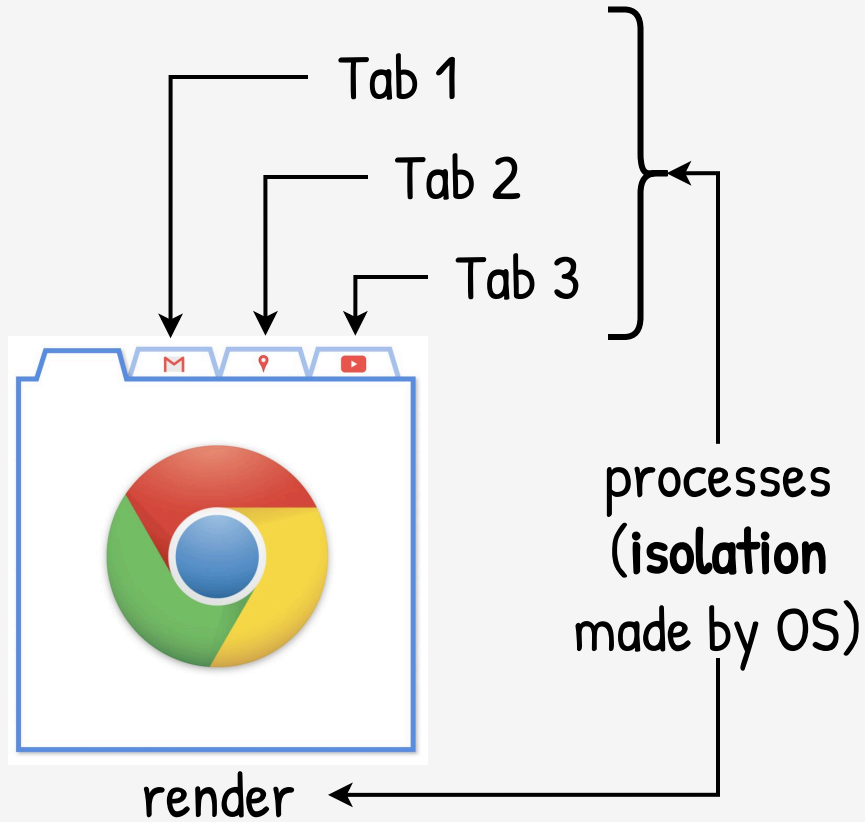










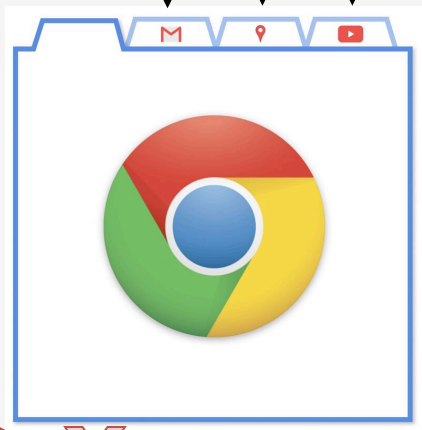




Tab 1

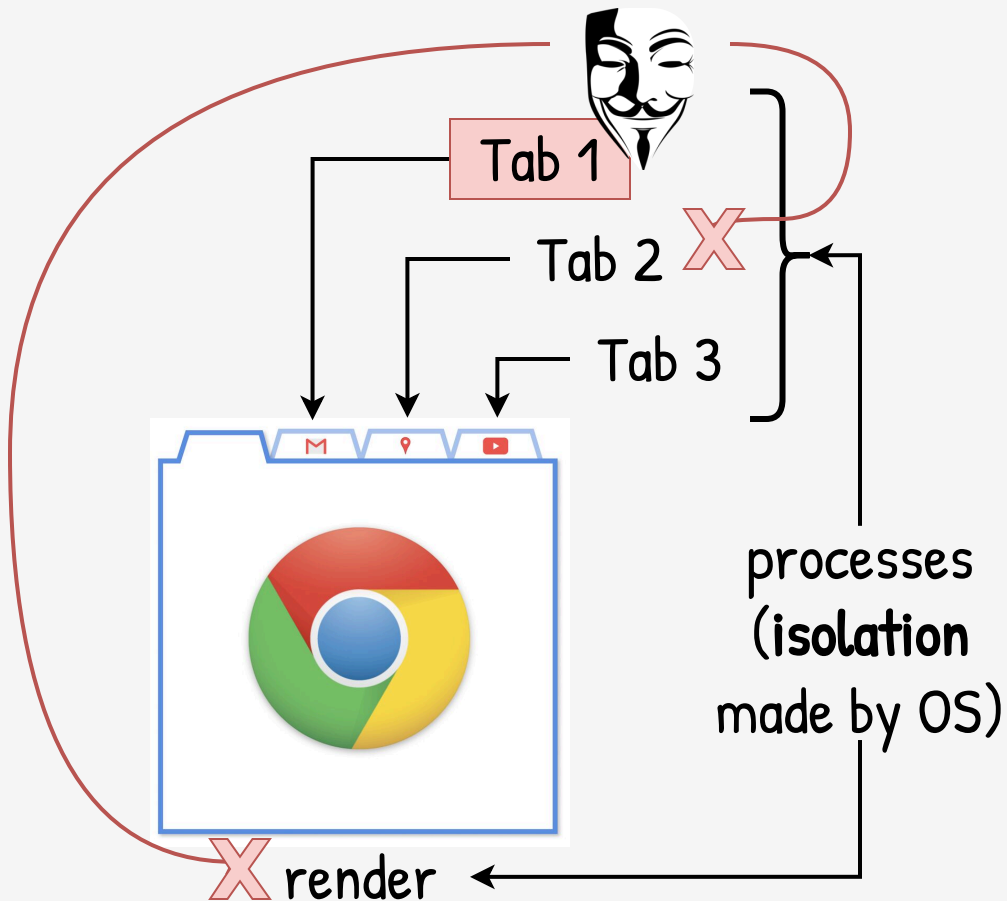
Tab 2 X

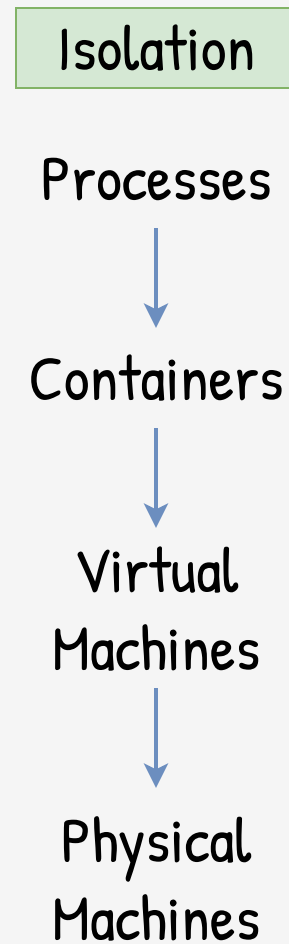
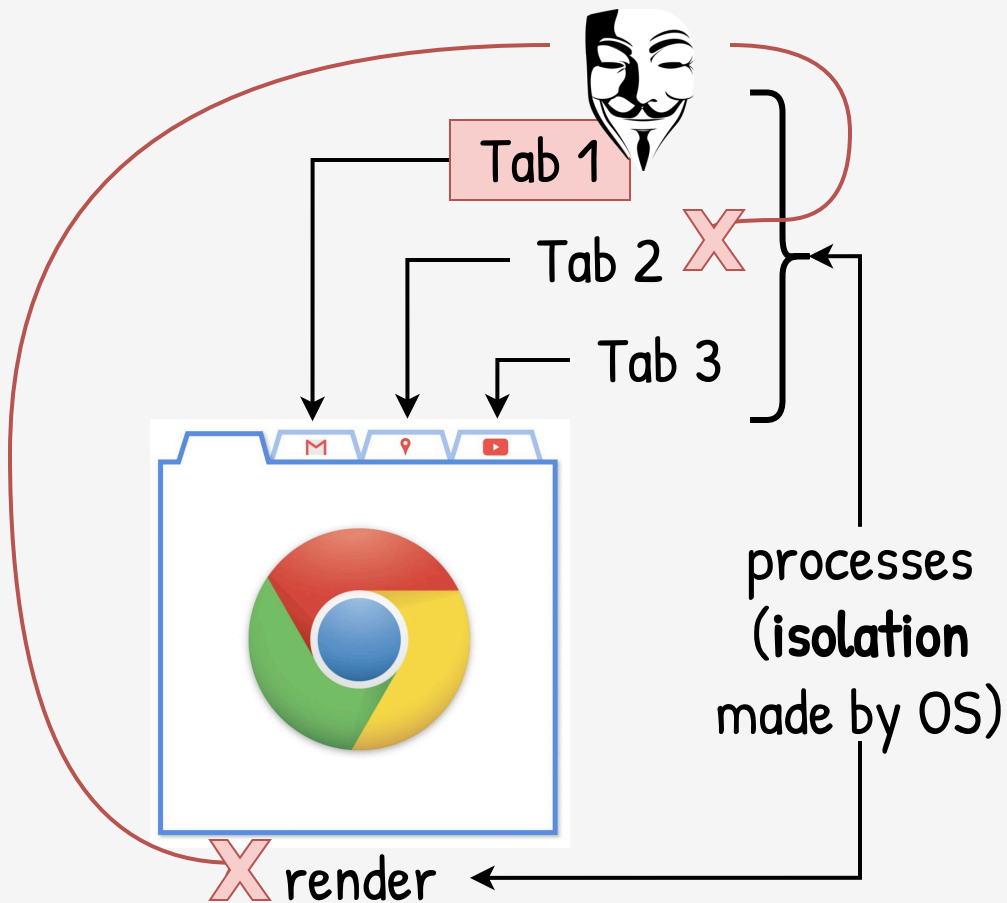
Tab 3



X render

processes
(isolation
made by OS)

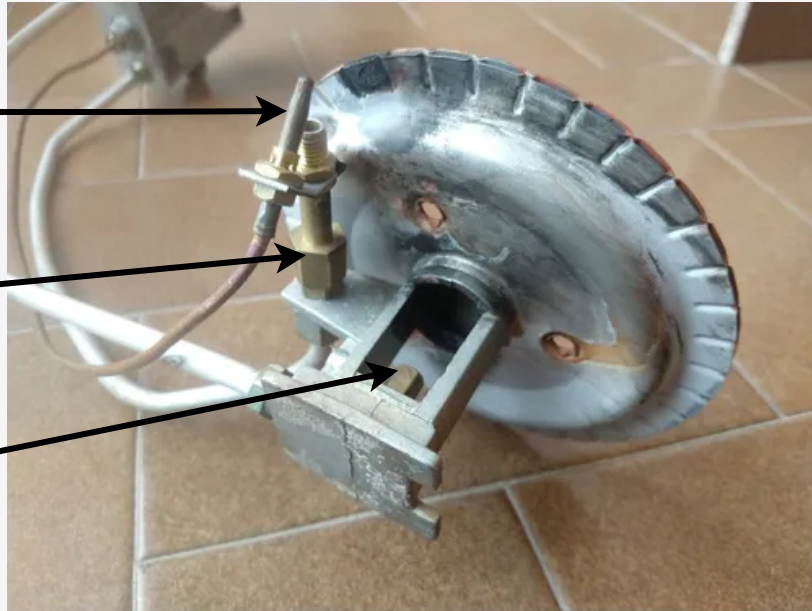




Thermocouple

"Pilot" pipe

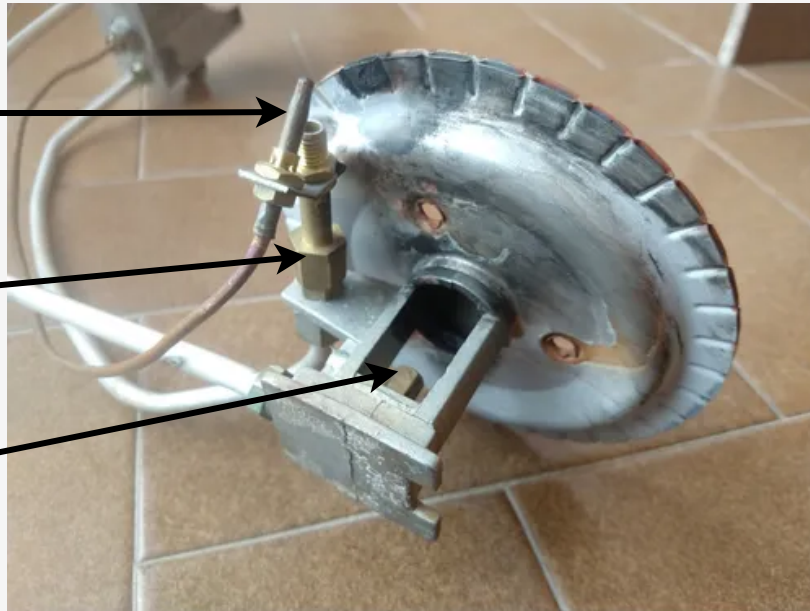
Main pipe



Thermocouple

"Pilot" pipe

Main pipe



Simple

Fail Safe

Prevent

Sec in Depth

Mitigate

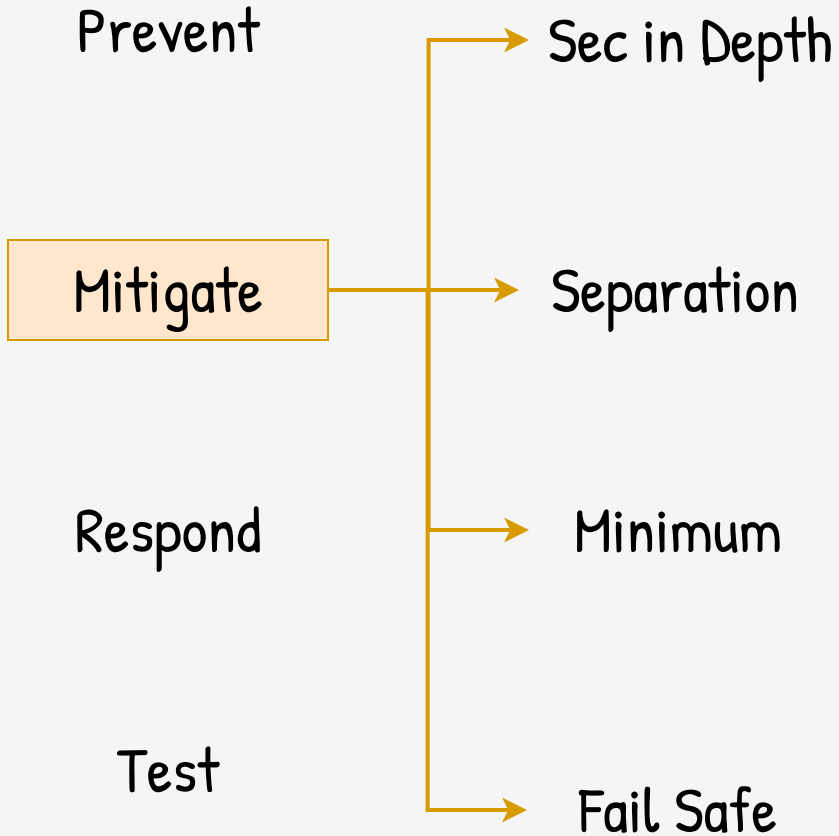
Separation

Respond

Minimum

Test

Fail Safe



Prevent

Sec in Depth

Mitigate

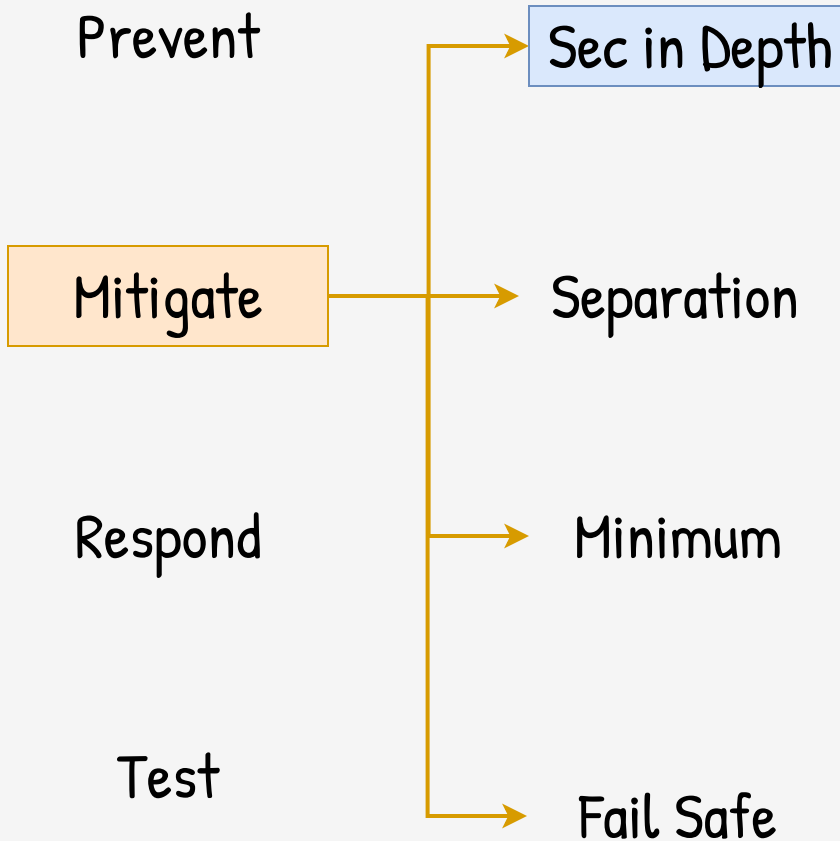
Separation

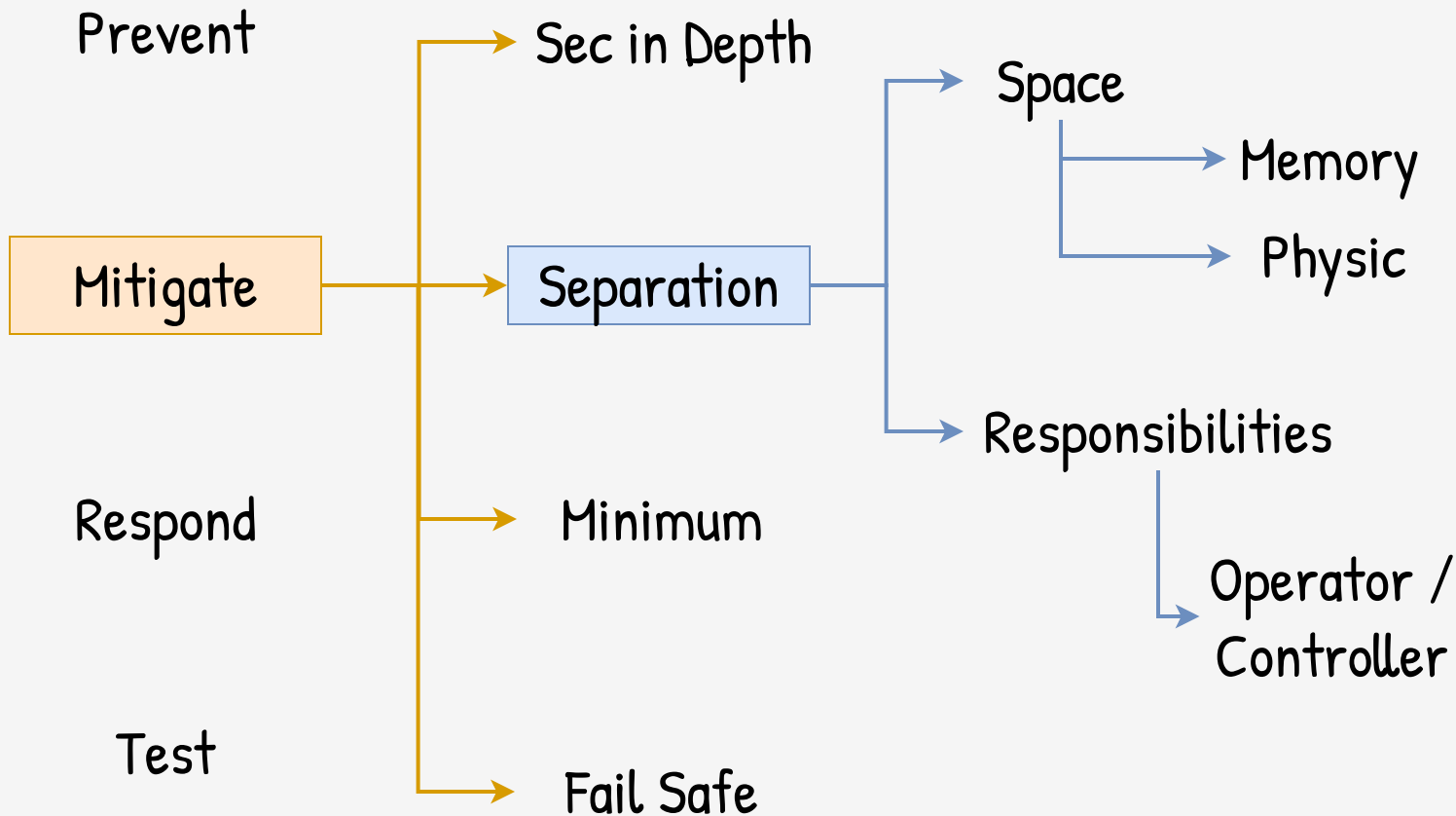
Respond

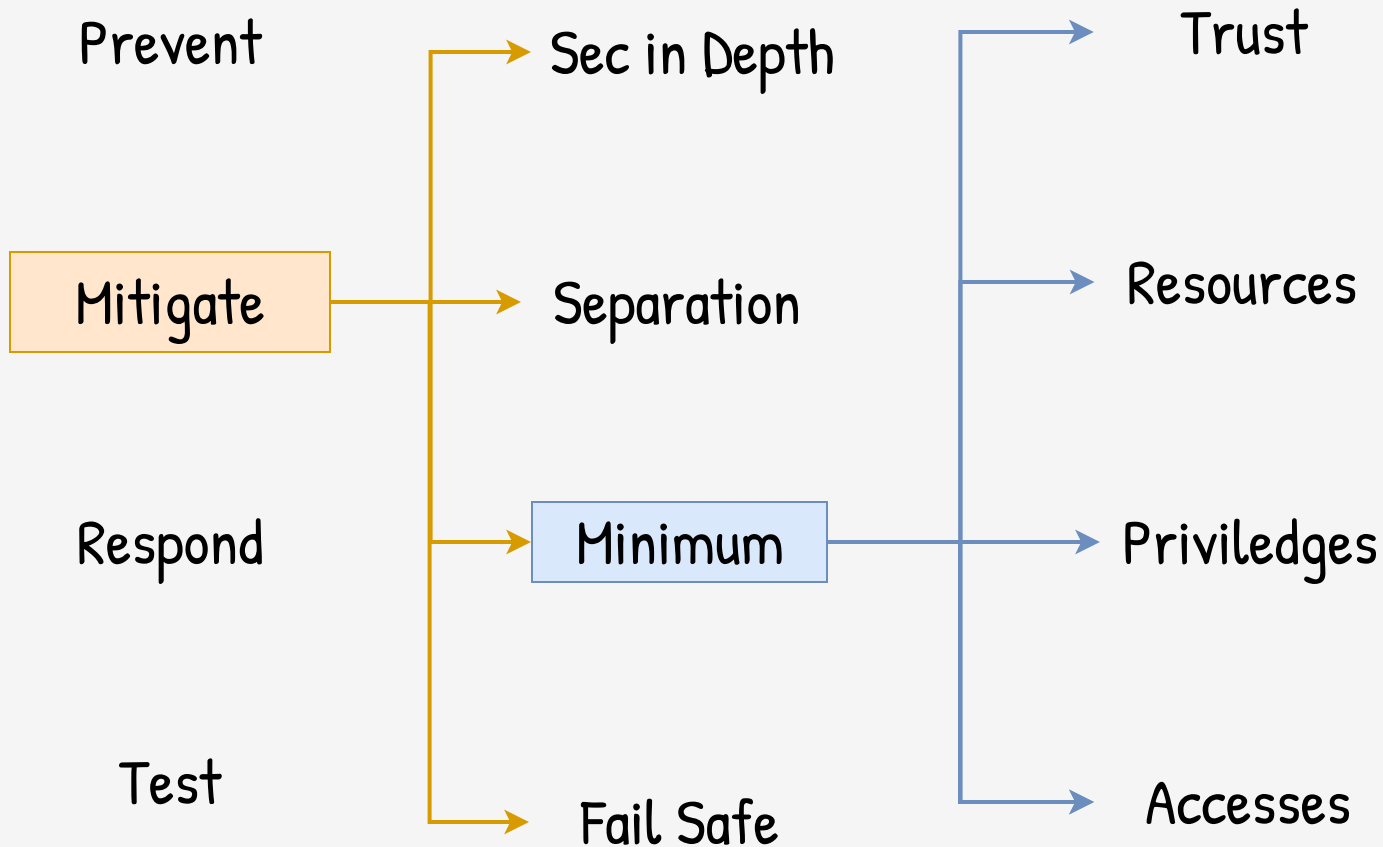
Minimum

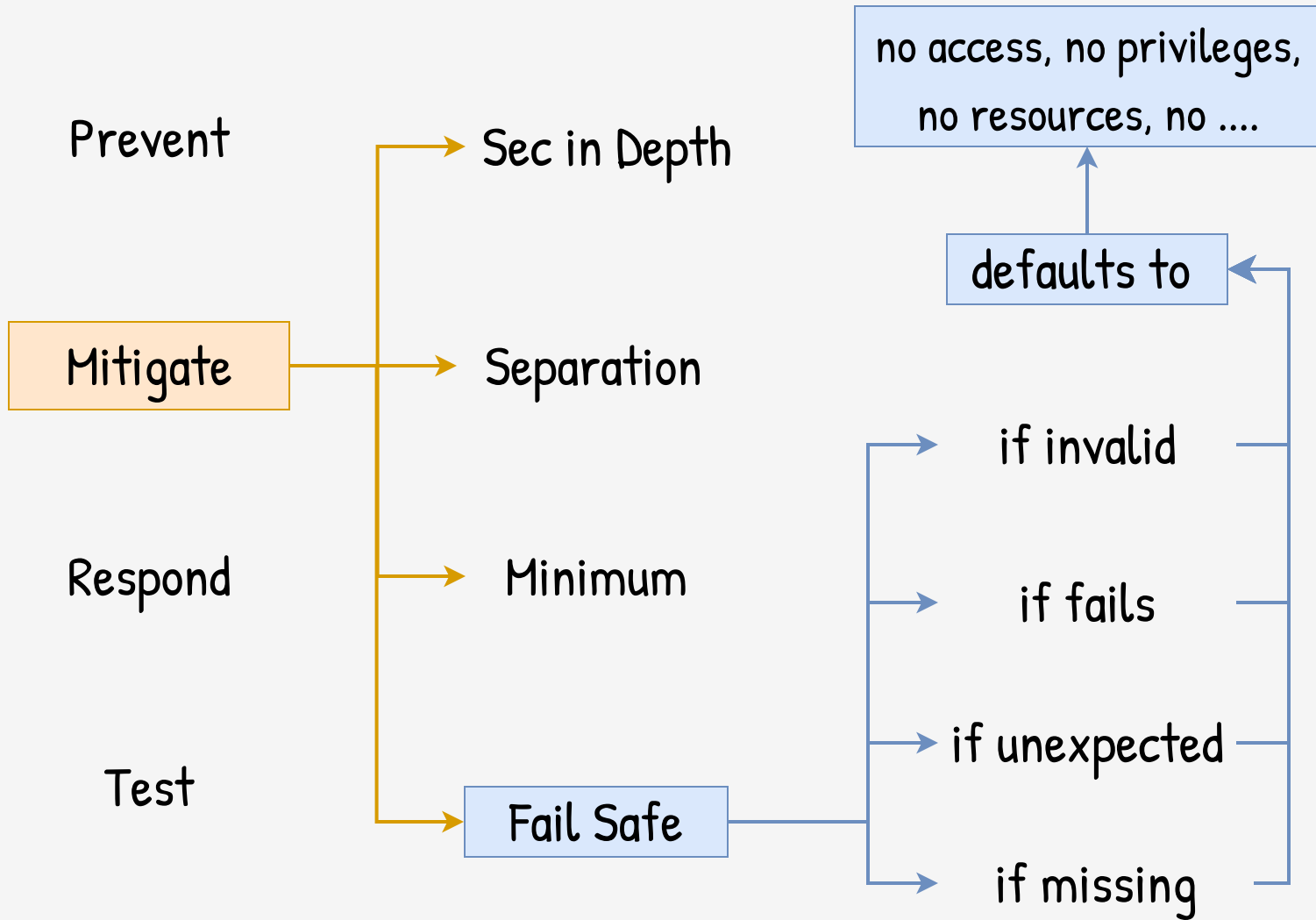
Test

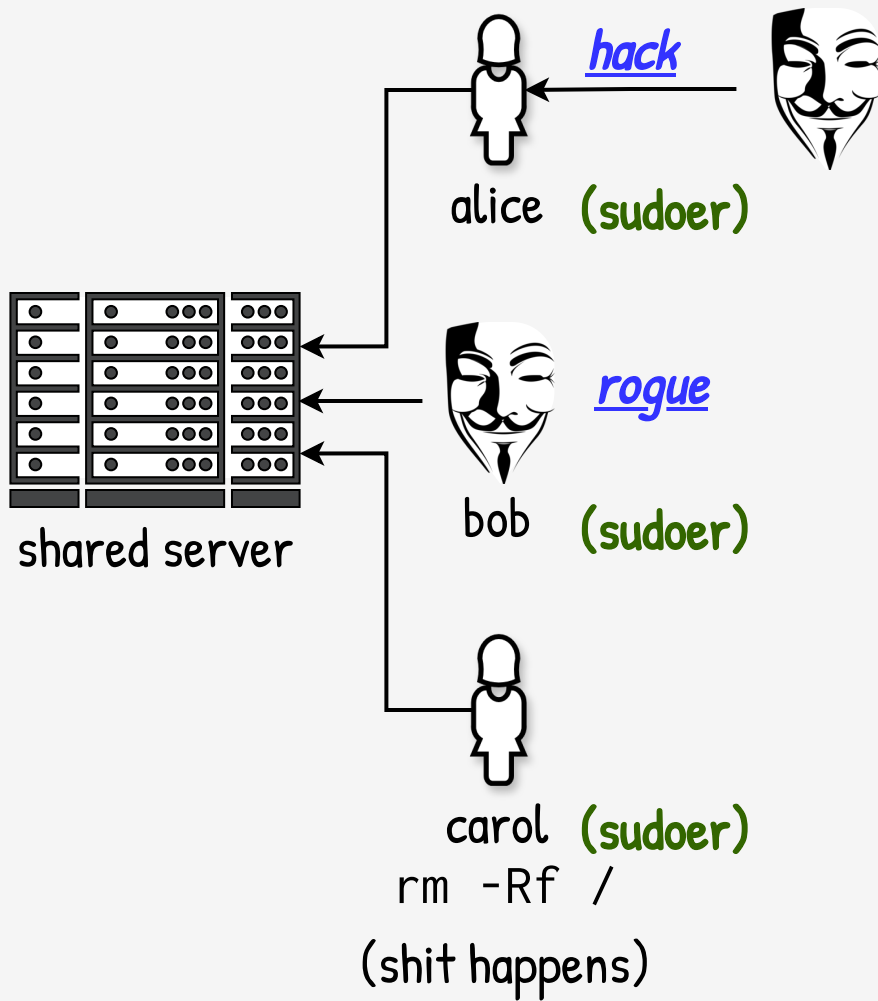
Fail Safe

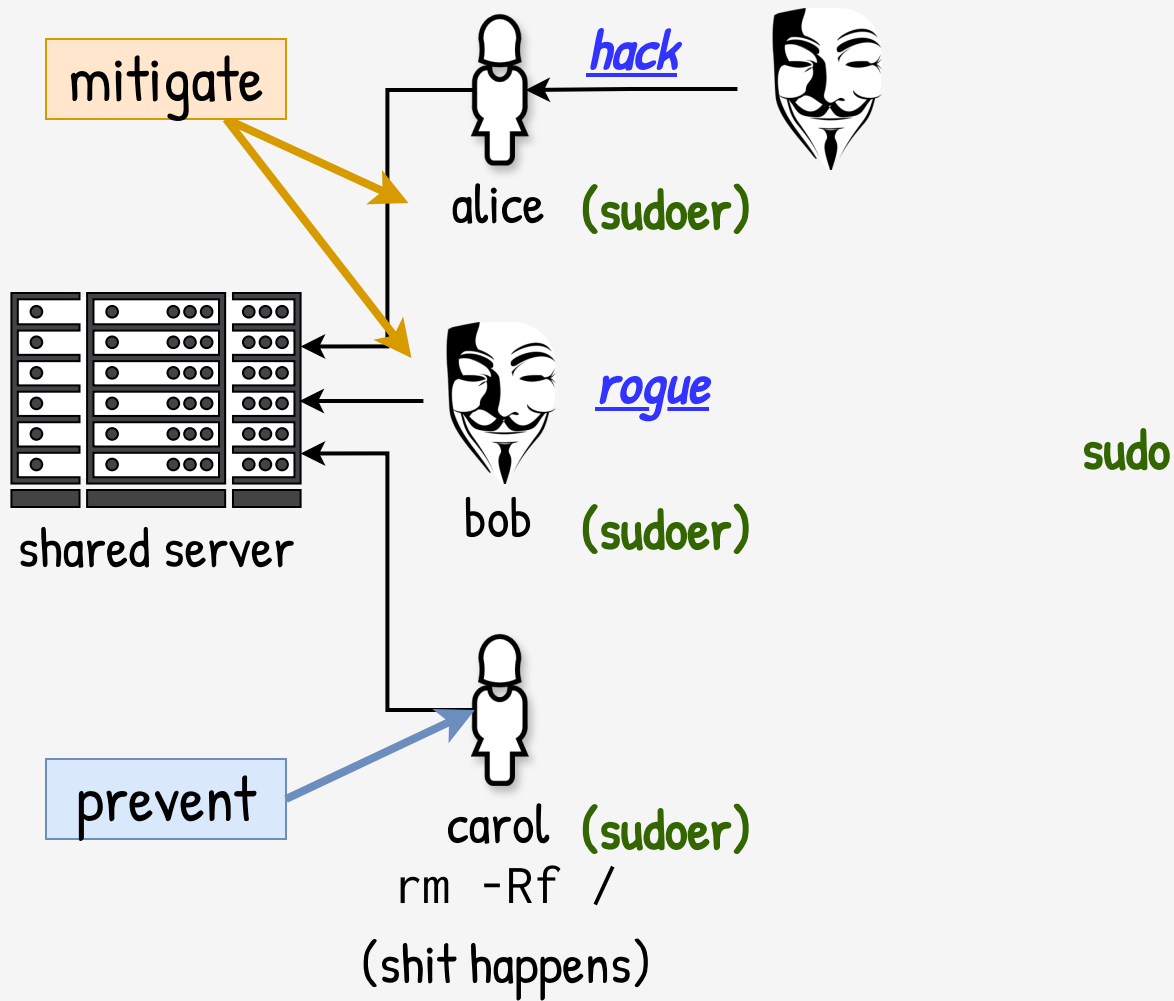


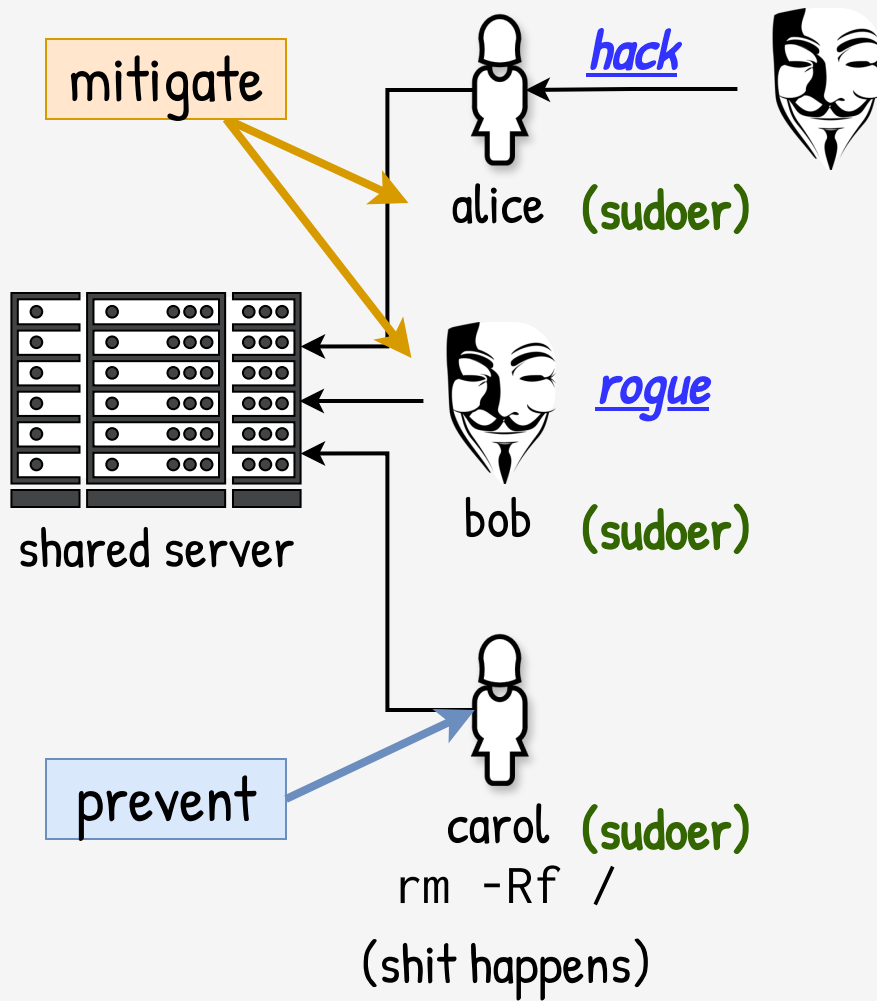












Prevent

Mitigate

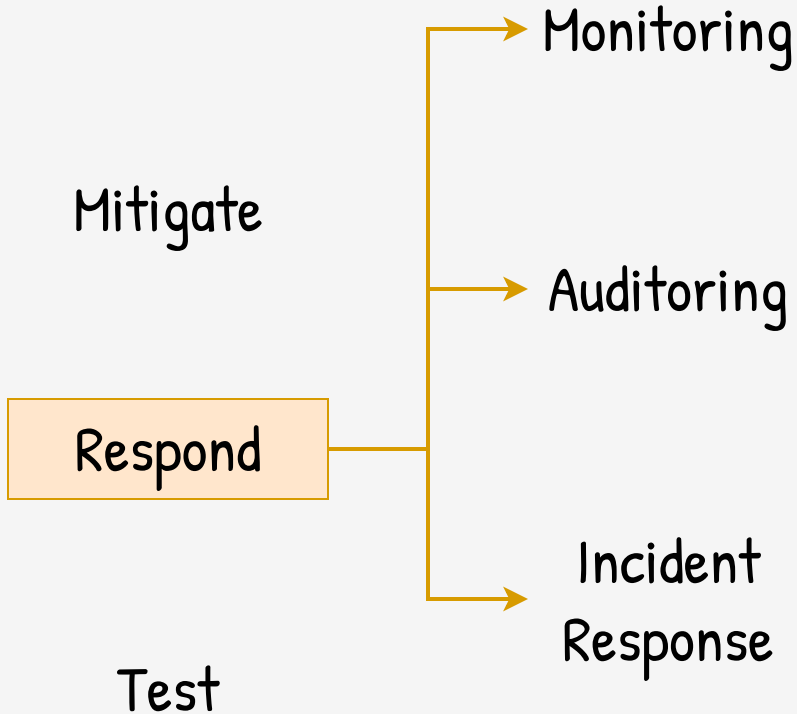
Respond

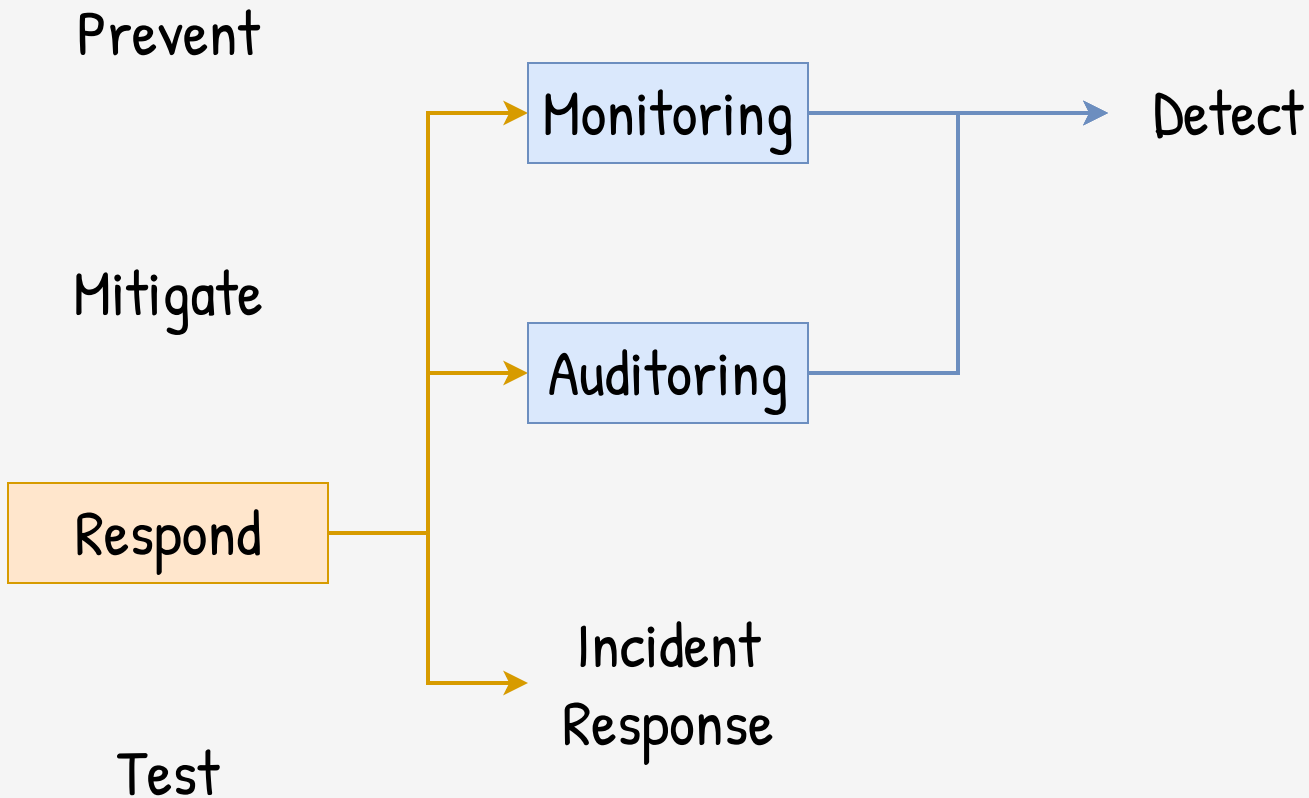
Test

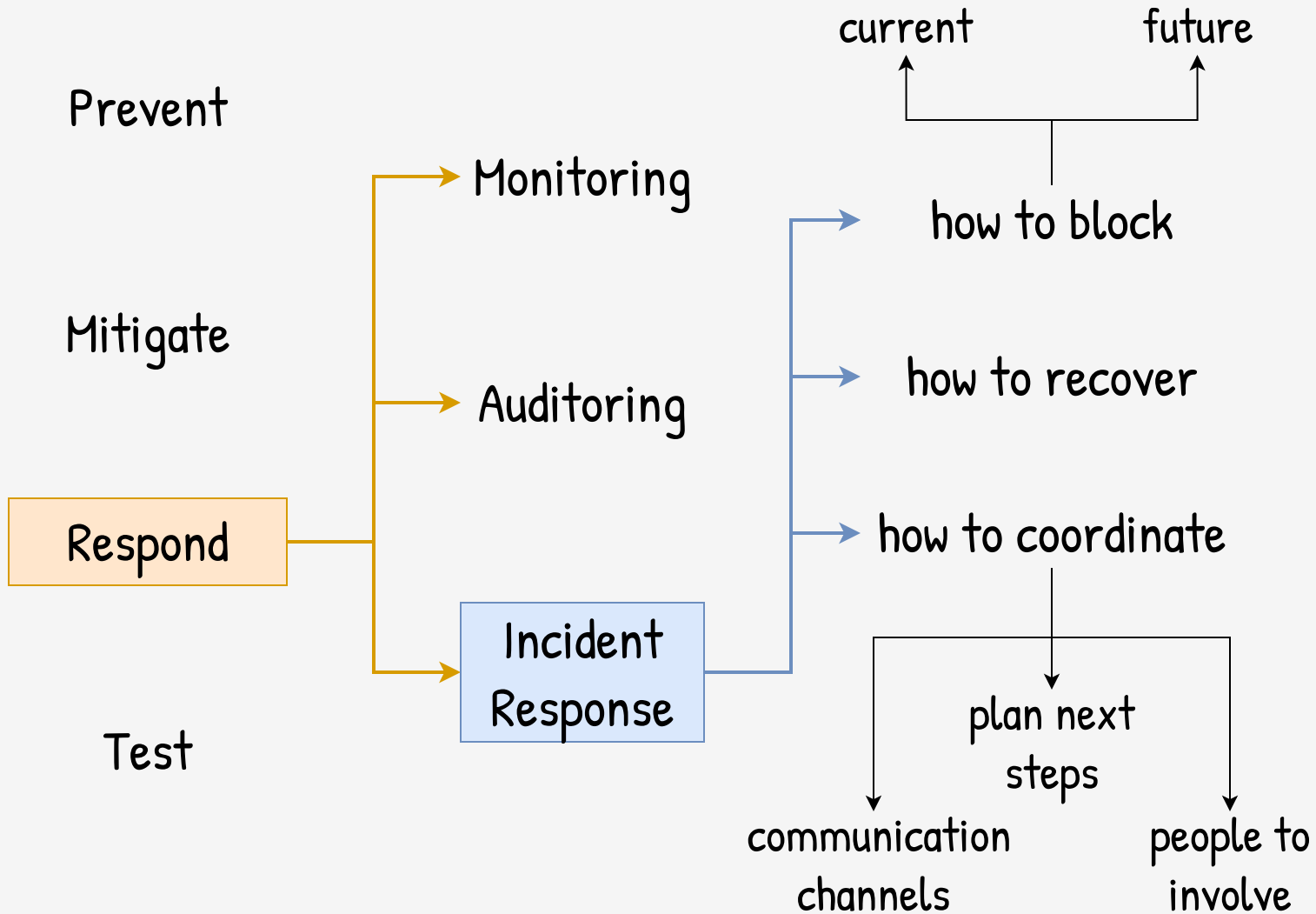
Monitoring

Auditing

Incident
Response







Prevent

Mitigate

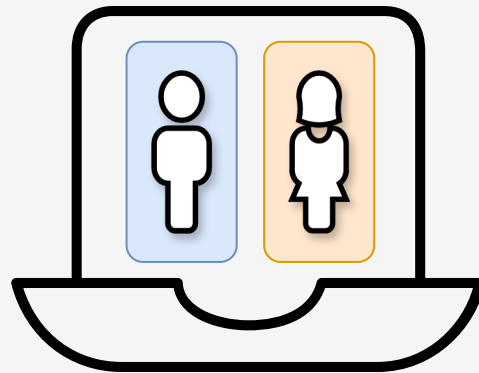
Respond

Test

Pentest /
Red Team

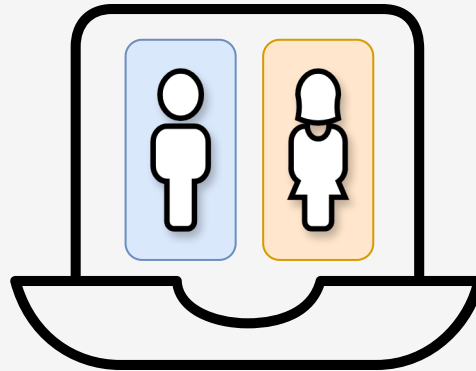
Test your
defenses





voting machine

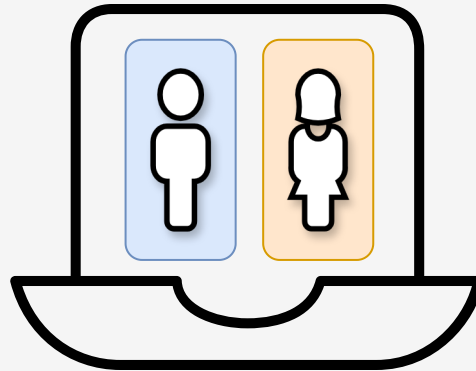
Think Like an Attacker



voting machine

Think Like an Attacker

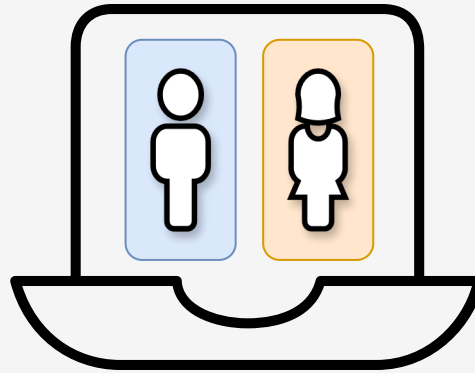
How does it
work?



voting machine

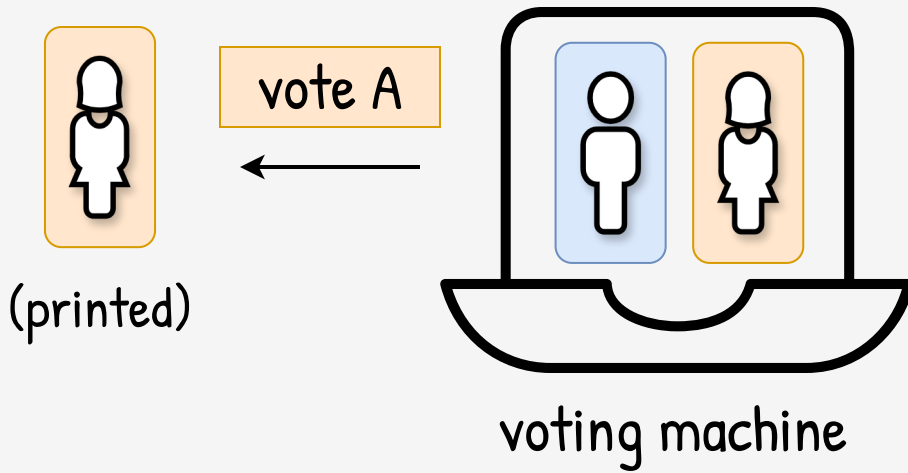
Think Like an Attacker

How does it
work?



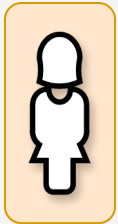
voting machine

How can we
hack it?



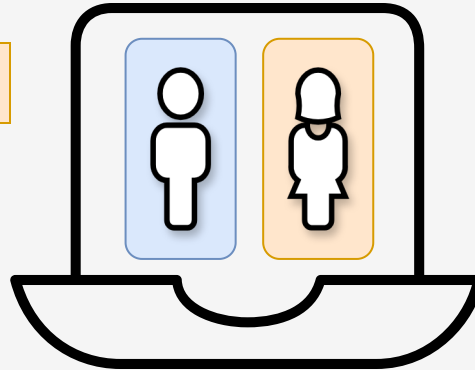
vote A

(NFC)



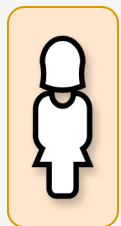
(printed)

vote A



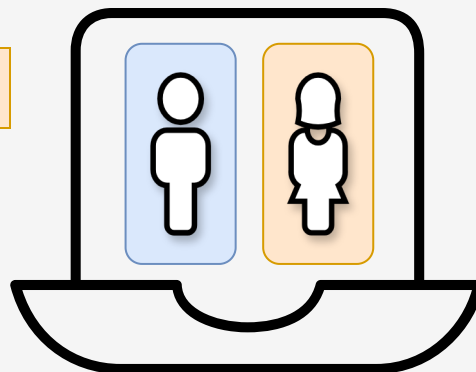
voting machine

vote A
(NFC)

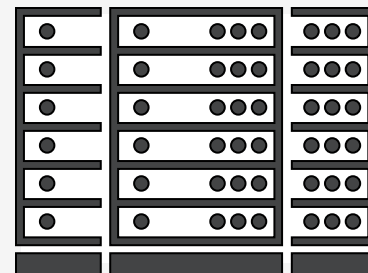


(printed)

vote A



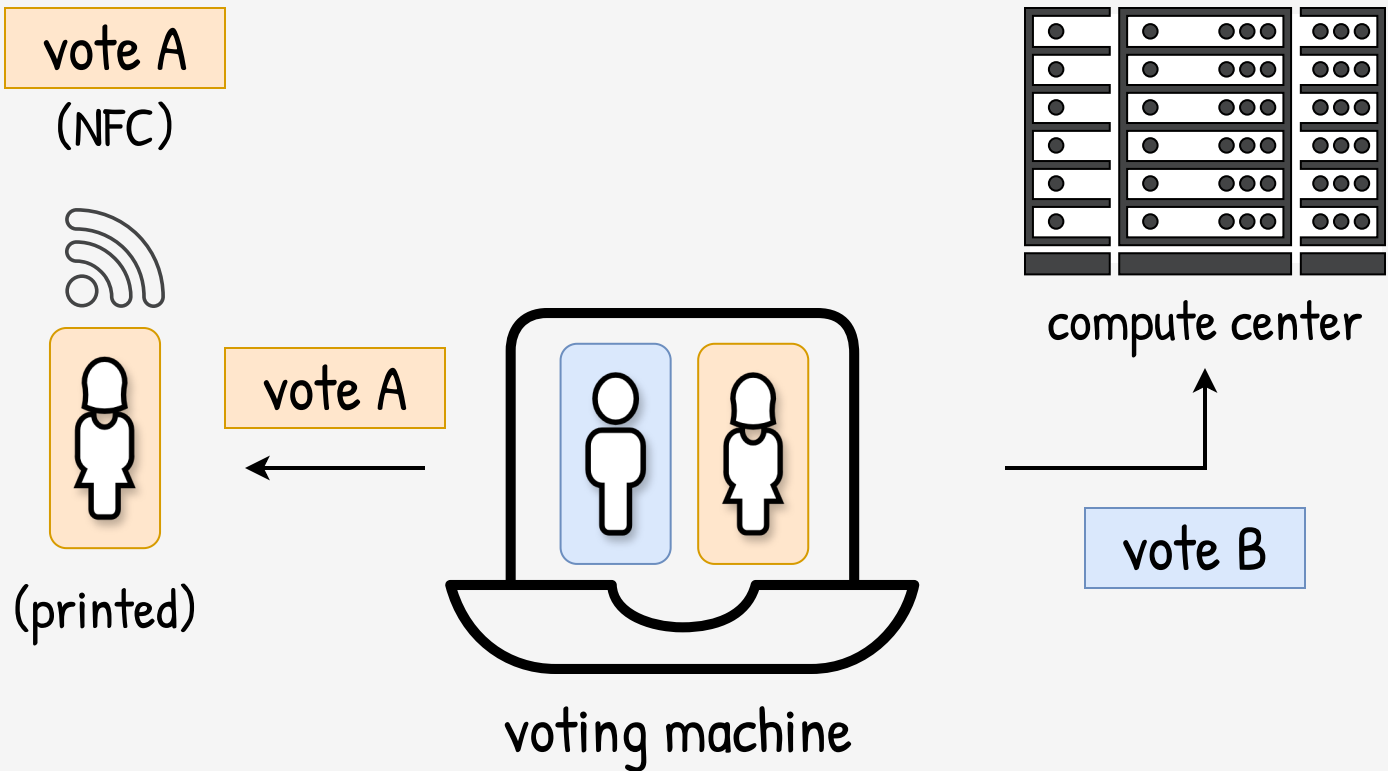
voting machine



compute center



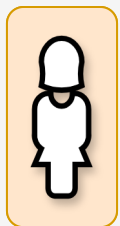
vote A



Opaque (not open).
How the voter could **check**?
How could she **trust**?

vote A

(NFC)



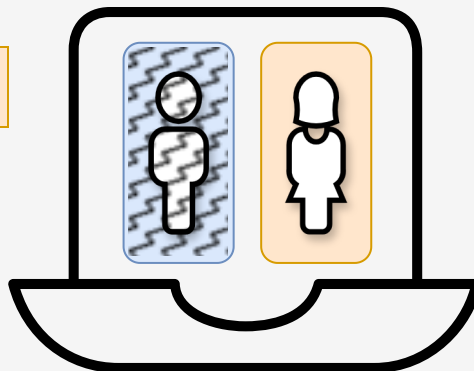
(printed)

vote A



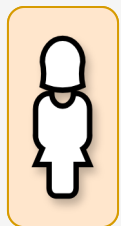
(check)

vote A



voting machine

vote B
(NFC)



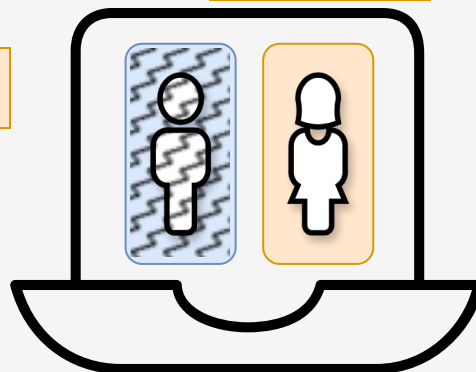
(printed)

vote A



(check)

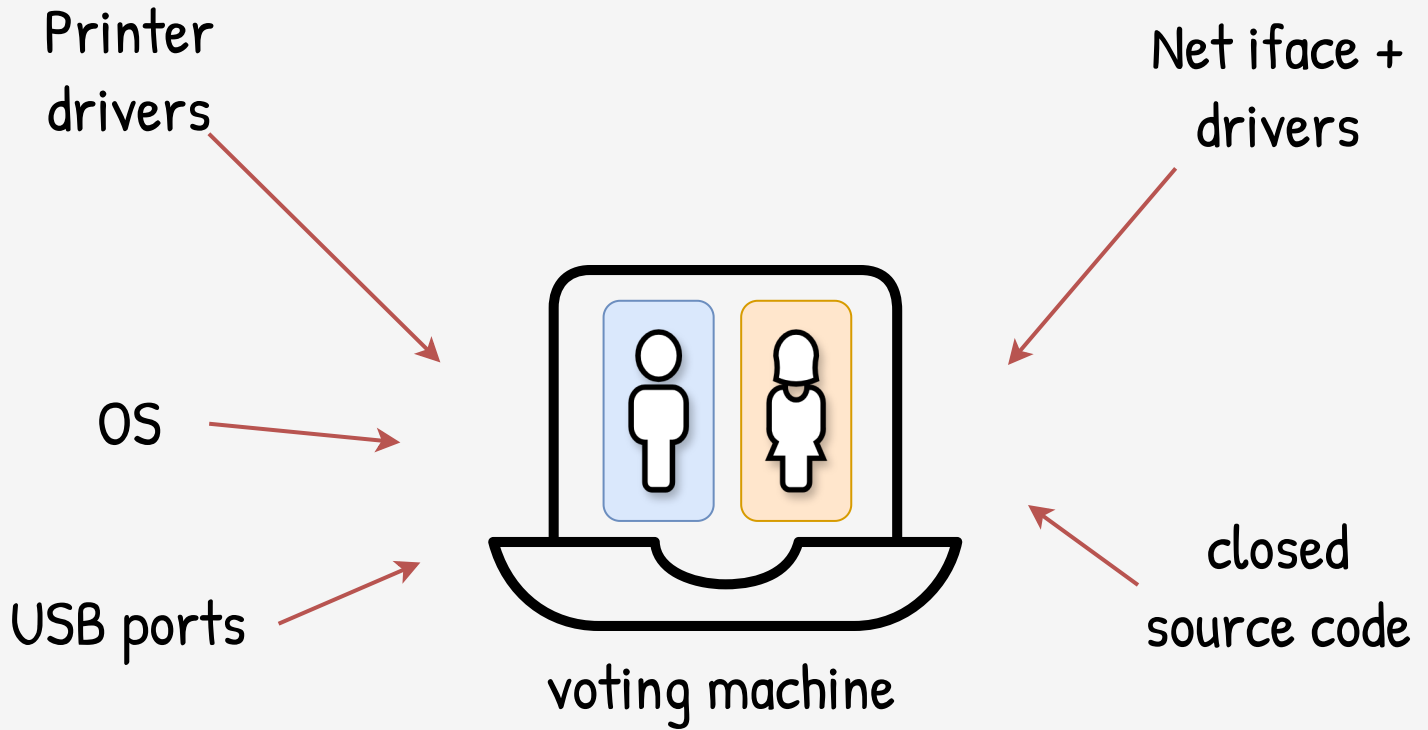
vote A



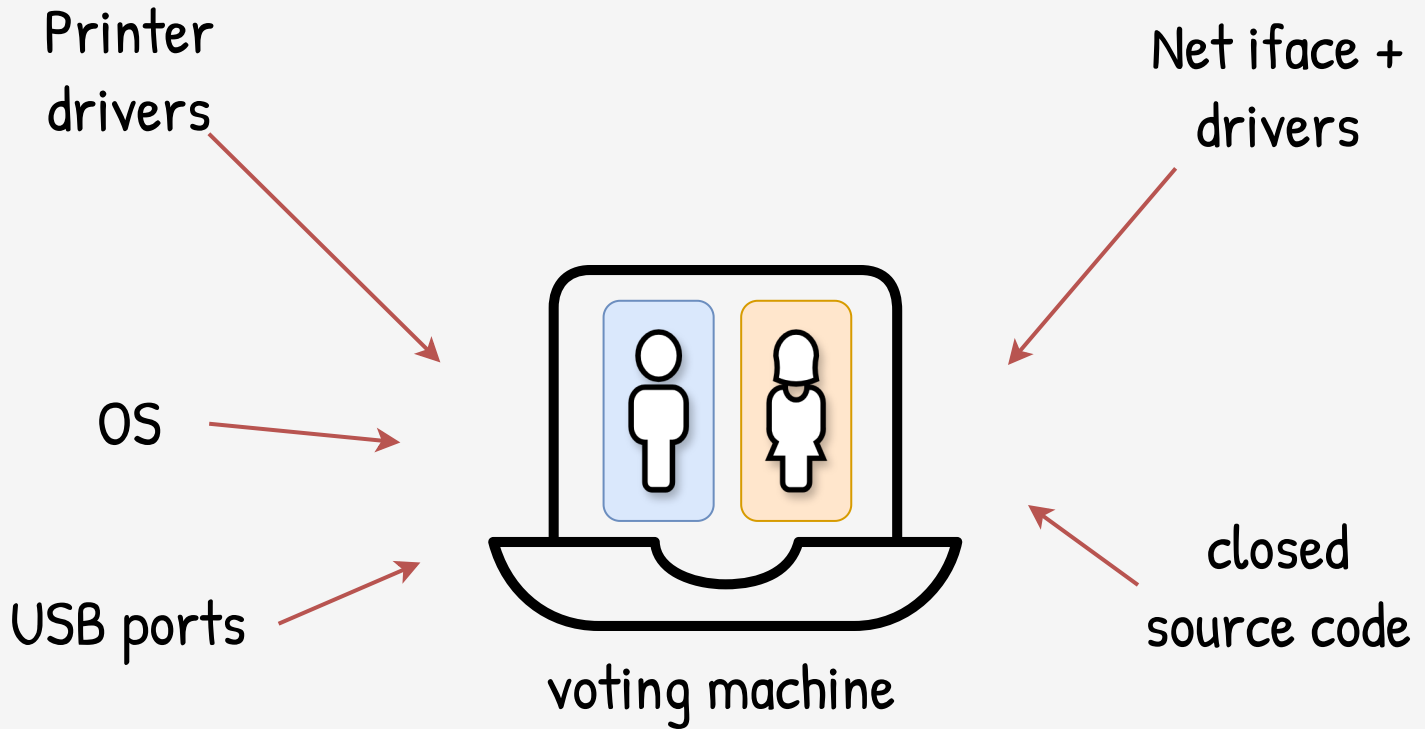
voting machine

No role separation:

Same machine for voting **and**
for controlling the vote



<https://www.youtube.com/watch?v=HwyN6P83HcY>

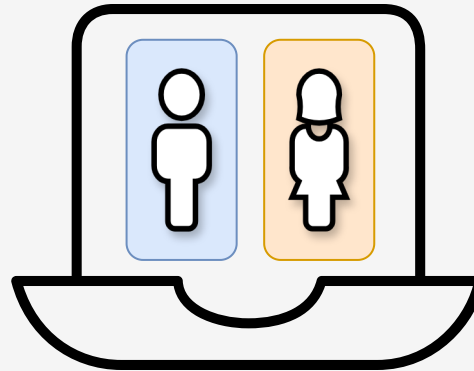


<https://www.youtube.com/watch?v=HwyN6P83HcY>

Complex (not simple).
How anyone can **verify** that the
machine **work as it should**?

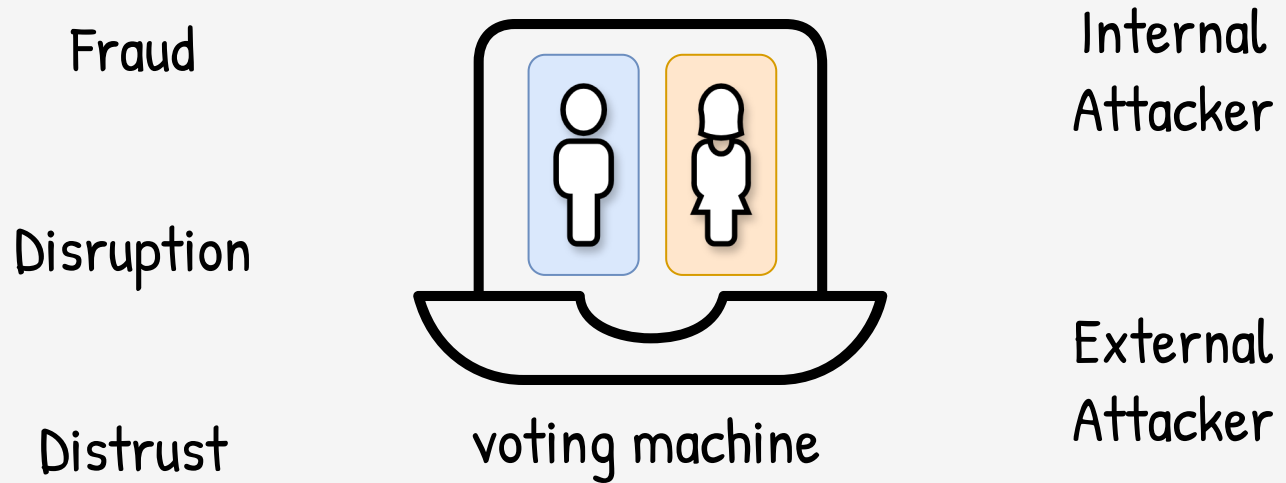
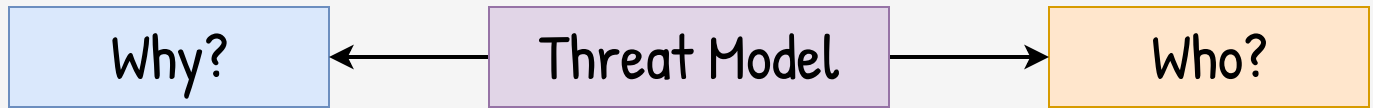


Fraud



voting machine

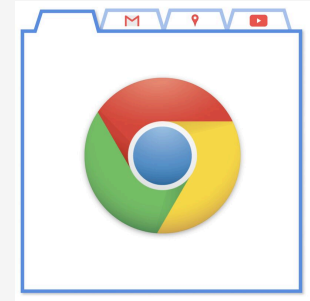
Internal
Attacker



Takeaways

Security goes
beyond software

Software



Hardware



People



Defense is not just
against an external
hack, it's against
real shit things happen